

# Open redirect by url encoding in gradio-app/gradio



Valid

Reported on Jul 4th 2024

## Description

Hi team while testing , i found that the there is a bypass for the <https://huntr.com/bounties/35aaea93-6895-4f03-9c1b-cd992665aa60> issue which can be used to redirect users to malicious website. This is attained through URL encoding .

## Proof of Concept

Visit the POC URL <http://localhost:7860/file=http%3A%2F%2Fgoogle.com>

```
GET /file=http%3A%2F%2Fgoogle.com HTTP/1.1
Host: localhost:7860
Accept-Encoding: gzip, deflate, br
Accept-Language: en-IN,en-GB;q=0.9,en-US;q=0.8,en;q=0.7,fr;q=0.6,ml;q=0.5
Priority: u=0, i
Accept-Encoding: gzip, deflate
Accept-Language: en-US
Cookie: _ga_R1FN4KJKJH=GS1.1.17897865150.1.0.1714449150.0.0.0; _ga=GA1.1.1786736.81
Connection: close
```

```
HTTP/1.1 302 Found
date: Wed, 03 Jul 2024 17:41:50 GMT
server: uvicorn
content-length: 0
location: http://google.com
connection: close
```

## Impact

User can be redirect to malicious site.

## Occurrences



## References

- [https://portswigger.net/kb/issues/00500100\\_open-redirection-reflected](https://portswigger.net/kb/issues/00500100_open-redirection-reflected)



We are processing your report and will contact the **gradio-app/gradio** team within 24 hours. 2 years ago



D3IT4



D3IT4 modified the report 2 years ago



huntr-helper commented 2 years ago

[Admin](#)

This report was determined to not have enough information for the maintainer or the Huntr team to triage.

**Please add more details in all sections of the report.**

Additionally, at least one PoC (Proof of Concept), needs to be provided. We *strongly* prefer the PoC to be in any of the following formats:

- Sequence of cURL commands
- A script in any programming language
- A Metasploit Module

Please note: while videos demonstrating exploitation are a welcomed addition to the report, they should not be used as a replacement for the PoC.



huntr-helper modified the Severity from Medium (5.4) to None (0) 2 years ago



We have contacted a member of the **gradio-app/gradio** team and are waiting to hear back 2 years ago



We have sent a follow up to the **gradio-app/gradio** team. We will try again in 4 days. 2 years ago



We have sent a second follow up to the **gradio-app/gradio** team. We will try again in 7 days. 2 years ago



We have sent a third follow up to the **gradio-app/gradio** team. We will try again in 14 days. 2 years ago



We have sent a fourth follow up to the **gradio-app/gradio** team. We will send a final notification 48 hours before report publication. a year ago



Dan McInerney modified the Severity from None (0) to High (7.2) a year ago



**Dan McInerney** modified the Severity from High (7.2) to Medium (5.4) a year ago

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



✓ **Dan McInerney** validated this vulnerability a year ago

Replicated.

\$ **govindpalakkal** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

**CVE-2024-8021** assigned to this report. a year ago

⚠ We have sent a warning to the **gradio-app/gradio** team to inform them that this report will be published in 48 hours a year ago

✉ We have notified the **gradio-app/gradio** maintainers about this report in their weekly follow-up a year ago

This vulnerability has now been published a year ago



**Chiencp** commented a year ago

Can you make this cve public?

**CVE-2024-8021** has now been published 10 months ago

[Sign in](#) to join this conversation

## CVE

CVE-2024-8021

Published

## Vulnerability Type

CWE-601: Open Redirect

## Severity

Medium (5.4)

Attack vector

Network

Attack complexity

Low

Privileges required

None

User interaction

Required

|                 |           |
|-----------------|-----------|
| Scope           | Unchanged |
| Confidentiality | Low       |
| Integrity       | Low       |
| Availability    | None      |

[Open in visual CVSS calculator](#) 

Registry

Pypi

Affected Version

Latest

Visibility

Public

Status

Awaiting fix

Disclosure Bounty

\$125

Fix Bounty

\$31.25

Found by



D3IT4

@govindpalakkal

MIDDLEWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.

